

# System Requirements Specification Platform Pembayaran Digital dan Manajemen Risiko Operasional

Nomor Dokumen: SRS-ARCPAY/ENG/2026/009

Jenis Dokumen: System Requirements Specification (SRS)

Organisasi: ArcPay Teknologi Finansial

Unit Pemilik: Divisi Product Engineering

Tanggal Berlaku: 15 Maret 2026

---

## Kendali Dokumen

| Atribut | Nilai |

| --- | --- |

| Versi | 1.8 |

| Disusun oleh | Lead System Analyst |

| Ditinjau oleh | Head of Risk & Compliance |

| Disetujui oleh | Chief Technology Officer |

| Klasifikasi dokumen | Internal Rahasia |

| Status | Berlaku dengan revisi minor |

## Daftar Isi

- 1. Pendahuluan
- 2. Latar Belakang Organisasi
- 3. Ruang Lingkup dan Sasaran
- 4. Istilah dan Definisi
- 5. Tata Kelola dan Pengambilan Keputusan
- 6. Klasifikasi Informasi dan Pengelolaan Aset
- 7. Penggunaan Email, Internet, dan Perangkat Kerja
- 8. SDM: Rekrutmen, Onboarding, dan Offboarding
- 9. Kesadaran dan Kompetensi Keamanan Informasi
- 10. Pengamanan Fisik dan Lingkungan Kerja
- 11. Manajemen Identitas, Akses, dan Kriptografi
- 12. Operasi TI: Patch, Konfigurasi, dan Perubahan
- 13. Pemantauan, Pencatatan, dan Respons Insiden
- 14. Keandalan Layanan: Backup, Pemulihan, dan Keberlanjutan
- 15. Pengembangan Sistem dan Pengujian Keamanan
- 16. Penutup
- Lampiran A. Matriks Peran
- Lampiran B. Alur Komunikasi

## 1. Pendahuluan

Dokumen spesifikasi ini mendefinisikan kebutuhan fungsional dan nonfungsional untuk platform pembayaran digital ArcPay yang melayani transfer dana, disbursement merchant, verifikasi identitas, dan

pelaporan transaksi. Sifat layanan yang selalu aktif menuntut desain sistem yang andal, aman, dan mampu dipulihkan dengan cepat ketika terjadi gangguan.

ArcPay berkembang dari tim kecil dengan siklus rilis sangat cepat. Pola tersebut menghasilkan inovasi produk yang kompetitif, namun juga meninggalkan variasi dokumentasi antarfitur. Dokumen ini mengonsolidasikan kebutuhan lintas divisi agar proses pengembangan, operasi, dan pengawasan memiliki rujukan tunggal yang dapat diaudit secara internal.

## **2. Latar Belakang Organisasi**

Sebagai perusahaan teknologi finansial tahap pertumbuhan, ArcPay mengoperasikan layanan pada infrastruktur cloud publik dan pusat data mitra pembayaran. Struktur organisasi menggabungkan engineering, fraud monitoring, customer operations, legal, dan people operations dengan koordinasi matriks untuk pengambilan keputusan harian.

Sebagian domain teknis telah menunjukkan kematangan tinggi, misalnya orkestrasi layanan mikro, enkripsi data transit, dan proses deployment otomatis berbasis persetujuan. Namun, pertumbuhan cepat juga menyisakan area yang belum seragam, seperti inventaris aset endpoint tim lapangan, standardisasi ruang kerja bersama, dan konsistensi offboarding untuk kontraktor jangka pendek.

## **3. Ruang Lingkup dan Sasaran**

Ruang lingkup SRS meliputi modul onboarding pelanggan, pemrosesan transaksi, manajemen akun internal, deteksi anomali, rekonsiliasi, pelaporan, serta integrasi dengan mitra perbankan. Sasaran utama adalah menjaga integritas transaksi, keakuratan saldo, dan ketersediaan layanan pada jam operasional tinggi.

Dokumen ini juga memuat sasaran operasional terkait perilaku penggunaan perangkat kerja, media komunikasi digital, dan pengelolaan kredensial. Meskipun pedoman penggunaan yang dapat diterima telah dituangkan pada portal SDM, evaluasi periodik menunjukkan sebagian tim masih menggunakan kanal pesan pribadi untuk berbagi cuplikan log yang seharusnya tetap berada di repositori internal.

## **4. Istilah dan Definisi**

Istilah transaksi kritical merujuk pada aktivitas pemindahan dana yang memengaruhi saldo pelanggan atau merchant. Istilah data sensitif mencakup data identitas pelanggan, token transaksi, detail rekening, serta artefak investigasi fraud yang memerlukan pembatasan akses ketat.

ArcPay menggunakan label klasifikasi informasi berupa publik, operasional internal, terbatas unit, dan rahasia perusahaan. Praktik pelabelan telah berjalan baik pada repositori dokumen pusat, namun artefak sementara di lingkungan pengujian masih ditemukan tanpa label yang konsisten sehingga meningkatkan kemungkinan paparan yang tidak disengaja.

## **5. Tata Kelola dan Pengambilan Keputusan**

Keputusan arsitektur dan prioritas rilis ditetapkan melalui forum mingguan yang dihadiri engineering manager, product manager, risk representative, dan operations lead. Setiap perubahan besar wajib menyertakan analisis dampak terhadap layanan pelanggan, kapasitas infrastruktur, dan beban tim dukungan.

Pada kondisi insiden berdampak tinggi, keputusan perbaikan cepat kerap dilakukan langsung oleh tim on-call dengan koordinasi minimum agar layanan segera pulih. Walaupun efektif untuk menurunkan downtime, pendekatan ini sesekali meninggalkan ketidaksinkronan dokumentasi perubahan dan memperpanjang fase stabilisasi pascainsiden.

## **6. Klasifikasi Informasi dan Pengelolaan Aset**

Seluruh komponen server, kontainer, dan kunci aplikasi tercatat dalam katalog aset teknis yang terintegrasi dengan pipeline deployment. Pendekatan ini mempermudah pemetaan ketergantungan layanan serta identifikasi komponen yang terdampak ketika ditemukan kerentanan.

Di sisi perangkat pengguna, pencatatan laptop dan ponsel kerja untuk tim tetap relatif tertib, sedangkan perangkat milik kontraktor dan mitra support belum selalu terdaftar pada siklus yang sama. Akibatnya, beberapa pembaruan kebijakan perangkat dan verifikasi konfigurasi tidak menjangkau seluruh pihak dengan hak akses ke sistem internal.

## **7. Penggunaan Email, Internet, dan Perangkat Kerja**

ArcPay mewajibkan penggunaan domain email perusahaan untuk komunikasi terkait pelanggan, mitra bank, dan regulator. Fitur deteksi lampiran berbahaya, perlindungan tautan, serta peringatan pengiriman keluar organisasi telah diaktifkan untuk mengurangi risiko kebocoran data.

Meskipun demikian, audit komunikasi internal mencatat praktik forwarding notifikasi layanan ke akun pribadi demi kemudahan akses mobile saat di luar jam kerja. Kebiasaan ini muncul karena sebagian tim belum memanfaatkan sepenuhnya aplikasi resmi mobile workplace yang telah disediakan perusahaan.

## **8. SDM: Rekrutmen, Onboarding, dan Offboarding**

Untuk peran yang menangani alur pembayaran, perusahaan melakukan verifikasi identitas, referensi pekerjaan, dan evaluasi integritas profesional sebelum penawaran final. Onboarding mencakup sesi pemahaman risiko bisnis, simulasi skenario insiden, serta penandatanganan komitmen kerahasiaan data pelanggan.

Pada fase offboarding karyawan tetap, penarikan akses sistem berjalan terotomasi melalui sinkronisasi HRIS dengan direktori identitas. Namun, untuk kontraktor berbasis proyek, pemutusan akses masih memerlukan konfirmasi manual dari vendor manager, sehingga terdapat jeda waktu pada beberapa kasus terminasi kontrak mendadak.

## **9. Kesadaran dan Kompetensi Keamanan Informasi**

Program pelatihan ArcPay menekankan praktik aman dalam pengembangan perangkat lunak, pengelolaan token, dan komunikasi insiden antar tim. Tingkat kelulusan modul dasar relatif tinggi karena materi diintegrasikan ke target kinerja onboarding triwulan pertama.

Untuk topik lanjutan seperti analisis log forensik dan penanganan kampanye phishing bertarget, partisipasi belum merata antar squad. Beberapa tim produk menunda pelatihan karena tekanan roadmap fitur, sehingga kemampuan respons mendalam belum setara pada seluruh unit engineering.

## **10. Pengamanan Fisik dan Lingkungan Kerja**

Kantor pusat ArcPay menggunakan akses kartu, area resepsionis terkendali, serta pemisahan area kerja tamu dan area operasional internal. Rak perangkat jaringan pada ruang infrastruktur lokal ditempatkan dalam kabinet terkunci dengan kontrol kunjungan vendor.

Praktik kerja hibrida menimbulkan tantangan baru, khususnya pada pengamanan layar dan percakapan sensitif di ruang publik. Meskipun pedoman clean desk dan clean screen telah diterbitkan, observasi internal menunjukkan penerapan belum konsisten di ruang kerja bersama dan lokasi kerja sementara.

## **11. Manajemen Identitas, Akses, dan Kriptografi**

Sistem produksi mensyaratkan autentikasi ganda untuk semua akun berprivilege, sementara hak akses aplikasi diatur berbasis peran yang ditinjau secara berkala oleh pemilik layanan. Kunci enkripsi dikelola terpusat dengan rotasi periodik dan pemisahan tugas antara pengelola platform dan pengembang fitur.

Pada aplikasi pendukung non-transaksional yang diadopsi sejak fase awal perusahaan, sebagian konfigurasi akses masih diwariskan dari pola lama berbasis grup umum. Dampaknya, penyesuaian hak akses saat perpindahan peran internal tidak selalu langsung tercermin pada seluruh alat kolaborasi.

## **12. Operasi TI: Patch, Konfigurasi, dan Perubahan**

Patch keamanan untuk komponen kritis diprioritaskan melalui siklus cepat dengan validasi pada lingkungan staging dan canary release. Seluruh perubahan besar harus memuat rencana rollback, metrik keberhasilan, dan pemilik tindakan pascadeploy.

Dalam periode promosi produk dengan lonjakan transaksi, tim terkadang menunda patch non-kritis untuk menjaga stabilitas performa. Keputusan ini didokumentasikan sebagai risiko operasional, tetapi akumulasi penundaan dapat memperpanjang eksposur sistem terhadap kelemahan yang telah diketahui.

## **13. Pemantauan, Pencatatan, dan Respons Insiden**

ArcPay menggabungkan telemetry aplikasi, log keamanan, dan metrik infrastruktur pada pusat observabilitas untuk mendeteksi anomali transaksi maupun gangguan layanan. Tim fraud dan tim operasi menjalankan jalur koordinasi bersama agar kejadian teknis dan kejadian bisnis ditangani sebagai satu konteks.

Cakupan pemantauan pada layanan inti sudah memadai, namun beberapa integrasi pihak ketiga masih menghasilkan jejak log terbatas. Ketika anomali terjadi pada rantai integrasi tersebut, investigasi sering memerlukan permintaan data tambahan ke mitra yang memperlambat penentuan akar masalah.

## **14. Keandalan Layanan: Backup, Pemulihan, dan Keberlanjutan**

Data transaksi dan konfigurasi kritis dicadangkan secara otomatis ke lokasi berbeda dengan verifikasi integritas berkala. Uji pemulihan dilakukan melalui simulasi gangguan terjadwal untuk memastikan prosedur operasional dapat dijalankan oleh tim lintas fungsi, bukan hanya oleh satu engineer senior.

Sementara itu, artefak analitik eksperimen produk tidak seluruhnya masuk ke skema backup yang sama karena dipandang bernilai sementara. Dalam beberapa kejadian, kehilangan data eksperimen memang tidak menghentikan layanan inti, tetapi menghambat evaluasi keputusan produk dan validasi model deteksi anomali.

## **15. Pengembangan Sistem dan Pengujian Keamanan**

ArcPay menerapkan secure coding guideline, pemeriksaan dependensi, dan tinjauan kode wajib pada jalur merge utama. Pengujian kerentanan otomatis dijalankan pada setiap pipeline rilis, disertai verifikasi manual untuk area dengan dampak finansial tinggi.

Kendala muncul pada proyek integrasi cepat dengan mitra baru, ketika tenggat bisnis mempersingkat waktu hardening dan dokumentasi arsitektur. Tim engineering tetap melakukan mitigasi minimum, namun beberapa temuan teknis ditunda ke backlog berikutnya sehingga memerlukan pengawasan ketat agar tidak menjadi utang operasional jangka panjang.

## **16. Penutup**

SRS ini menjadi acuan tunggal bagi pengembangan dan operasi platform ArcPay agar pertumbuhan produk berjalan seimbang dengan disiplin pengelolaan risiko. Dokumen ini akan diperbarui mengikuti perubahan model layanan, teknologi, dan lanskap ancaman yang relevan dengan industri keuangan digital.

ArcPay mengakui bahwa kematangan proses tidak berkembang secara serempak pada semua tim. Oleh karena itu, perbaikan berkelanjutan difokuskan pada area yang masih menunjukkan ketergantungan manual, kesenjangan dokumentasi, dan variasi penerapan standar kerja aman di lingkungan kerja hibrida.

### **Lampiran A. Matriks Peran**

Matriks peran dalam dokumen ini menggunakan prinsip akuntabilitas berlapis. Unit pemilik proses bertanggung jawab atas pelaksanaan harian, sementara fungsi tata kelola melakukan pengawasan periodik berbasis risiko. Pada praktiknya, beberapa unit operasional masih mengandalkan personel kunci tertentu untuk keputusan teknis, sehingga kesinambungan keputusan berpotensi terganggu pada saat rotasi pegawai. Oleh karena itu, pembaruan matriks peran ditetapkan minimal dua kali setahun agar pendelegasian kewenangan terdokumentasi dengan lebih baik.

### **Lampiran B. Alur Komunikasi**

Alur komunikasi internal menempatkan jalur eskalasi formal untuk kejadian yang berdampak pada layanan inti, data personal, dan integritas sistem. Selain jalur formal, masih terdapat praktik komunikasi informal melalui grup percakapan lintas unit yang mempercepat koordinasi namun sering tidak meninggalkan jejak keputusan yang memadai. Untuk menjaga konsistensi dan keterlacakan, setiap keputusan operasional yang diambil secara cepat harus dirangkum kembali ke dalam kanal resmi dalam waktu kerja yang sama.

## Lampiran C. Ground Truth SoA Simulasi (Output LLM RAG)

Lampiran ini merupakan \_ground truth\_ simulasi yang dirumuskan dari pola output model pada direktori RAG\rag\iso\_rag\_project\results (terutama combined\_results.csv, analysis\_report.md, dan DataThesis.md), lalu diselaraskan dengan narasi dokumen ArcPay Teknologi Finansial pada fokus domain platform pembayaran, engineering, risiko operasional.

| No  | Narasi Evidence Ringkas                                               | Prediksi Annex Control | Applicability | Implementation Status |
|-----|-----------------------------------------------------------------------|------------------------|---------------|-----------------------|
| --- | ---                                                                   | ---                    | ---           | ---                   |
| 1   | Forum arsitektur mingguan menetapkan prioritas keamanan layanan       | A.5.1                  | Yes           | Implemented           |
| 2   | Keputusan insiden darurat kadang mendahului dokumentasi formal        | A.5.27                 | Yes           | Partially Implemented |
| 3   | Inventaris aset cloud lengkap, endpoint kontraktor belum menyeluruh   | A.5.9                  | Yes           | Partially Implemented |
| 4   | Kebijakan email perusahaan kuat, forwarding ke akun pribadi masih ada | A.5.10                 | Yes           | Partially Implemented |
| 5   | Offboarding karyawan tetap otomatis, kontraktor masih manual          | A.5.11                 | Yes           | Partially Implemented |
| 6   | Klasifikasi data diterapkan pada repositori pusat                     | A.5.12                 | Yes           | Implemented           |
| 7   | Verifikasi personel pada fungsi pembayaran diterapkan sebelum akses   | A.6.1                  | Yes           | Implemented           |
| 8   | Pelatihan dasar wajib, pelatihan lanjutan belum merata per squad      | A.6.3                  | Yes           | Partially Implemented |
| 9   | Kebersihan ruang kerja hibrida belum konsisten                        | A.7.7                  | Yes           | Partially Implemented |
| 10  | Area kantor dipisah antara tamu dan internal                          | A.7.2                  | Yes           | Implemented           |
| 11  | RBAC dan MFA untuk privilege account telah aktif                      | A.8.2                  | Yes           | Implemented           |
| 12  | Rotasi kunci enkripsi terpusat berjalan periodik                      | A.8.24                 | Yes           | Implemented           |
| 13  | Patch kritikal diprioritaskan, non-kritikal kadang ditunda            | A.8.8                  | Yes           | Partially Implemented |
| 14  | Observabilitas terpusat ada, integrasi pihak ketiga terbatas          | A.8.15                 | Yes           | Partially Implemented |
| 15  | Backup data transaksi diuji dengan simulasi gangguan                  | A.8.13                 | Yes           | Implemented           |
| 16  | Secure coding pipeline diterapkan pada jalur merge utama              | A.8.28                 | Yes           | Implemented           |
| 17  | Pemisahan staging, canary, dan produksi telah dijalankan              | A.8.31                 | Yes           | Implemented           |
| 18  | Integrasi cepat mitra kadang menunda hardening penuh                  | A.8.25                 | Yes           | Partially Implemented |

Ringkasan ini sengaja memuat sinyal positif dan negatif secara bersamaan agar dataset tetap realistis untuk kebutuhan analisis SoA otomatis. Beberapa butir bernilai \*Partially Implemented\* untuk merepresentasikan kondisi organisasi yang telah memiliki kebijakan namun belum konsisten pada implementasi unit kerja tertentu.

## **Lampiran D. Narasi Tambahan untuk Pengayaan Dokumen**

Dalam evaluasi semesteran, organisasi menegaskan bahwa perbaikan tata kelola tidak cukup diukur dari keberadaan kebijakan tertulis, melainkan dari konsistensi penerapan lintas unit dan keterlacakan keputusan operasional. Pola ini penting karena banyak risiko muncul pada titik transisi proses, seperti perpindahan personel, perpindahan aset, dan perubahan konfigurasi layanan pada periode beban puncak.

Unit pengawasan internal mencatat bahwa praktik yang terlihat baik pada level pusat belum tentu tercermin di unit satelit, cabang, atau area operasional khusus. Oleh sebab itu, pendekatan evaluasi diarahkan pada pembuktian lapangan, termasuk verifikasi jejak audit, kecukupan dokumentasi persetujuan, dan ketepatan waktu tindak lanjut setelah temuan inspeksi.

Kapasitas SDM menjadi faktor pembeda utama antara unit yang mampu menjaga disiplin operasional dan unit yang masih bergantung pada inisiatif individu. Investasi pada pelatihan teknis, pelatihan perilaku kerja aman, serta simulasi insiden berkala terbukti mempercepat respons dan menurunkan insiden berulang yang disebabkan oleh kesalahan prosedural.

Pada aspek teknologi, organisasi menilai bahwa penguatan autentikasi, pemisahan hak akses, dan pemantauan log harus berjalan beriringan. Penerapan salah satu komponen tanpa komponen lain sering menghasilkan ilusi kendali: akses mungkin terlihat ketat, namun anomali tidak terdeteksi atau tidak dapat ditelusuri secara memadai ketika kejadian berlangsung lintas sistem.

Untuk menjamin kesinambungan layanan, kebutuhan pemulihan tidak hanya ditentukan oleh ketersediaan salinan cadangan, tetapi juga oleh kesiapan personel menjalankan prosedur di bawah tekanan waktu. Simulasi pemulihan yang melibatkan fungsi bisnis dan fungsi teknis sekaligus dinilai lebih representatif dibanding pengujian terbatas oleh tim infrastruktur saja.

Organisasi juga menekankan bahwa perubahan cepat tetap dapat dijalankan secara tertib apabila setiap perubahan memiliki pemilik yang jelas, catatan keputusan yang ringkas, dan verifikasi pascaperubahan. Praktik tersebut mengurangi risiko regresi tersembunyi, terutama ketika perubahan dilakukan pada jam non-standar untuk menjaga ketersediaan layanan.

Selain aspek teknis, keberhasilan penguatan tata kelola sangat dipengaruhi budaya eskalasi yang sehat. Unit kerja didorong untuk melaporkan kerentanan proses dan deviasi praktik tanpa menunggu terjadinya insiden besar, sehingga tindakan korektif dapat dilakukan lebih awal dan biaya pemulihan tetap terkendali.



## Lampiran E. Ground Truth Per Poin (Point-by-Point)

Ground truth berikut telah dikoreksi dengan referensi Control ID dari iso\_controls.json.

### Poin 1 - Pendahuluan

Deskripsi:

Dokumen spesifikasi ini mendefinisikan kebutuhan fungsional dan nonfungsional untuk platform pembayaran digital ArcPay yang melayani transfer dana, disbursement merchant, verifikasi identitas, dan pelaporan transaksi. Sifat layanan yang selalu aktif menuntut desain sistem yang andal, aman, dan mampu dipulihkan dengan cepat ketika terjadi gangguan.

ArcPay berkembang dari tim kecil dengan siklus rilis sangat cepat. Pola tersebut menghasilkan inovasi produk yang kompetitif, namun juga meninggalkan variasi dokumentasi antarfitur. Dokumen ini mengonsolidasikan kebutuhan lintas divisi agar proses pengembangan, operasi, dan pengawasan memiliki rujukan tunggal yang dapat diaudit secara internal.

Ground Truth (Terkoreksi):

Control ID: A.5.1

Control Title: Kebijakan keamanan informasi

Applicable: Yes

Implementation Status: Implemented

Alasan Ringkas: Menetapkan arah kebijakan keamanan/tata kelola tingkat organisasi.

### Poin 2 - Latar Belakang Organisasi

Deskripsi:

Sebagai perusahaan teknologi finansial tahap pertumbuhan, ArcPay mengoperasikan layanan pada infrastruktur cloud publik dan pusat data mitra pembayaran. Struktur organisasi menggabungkan engineering, fraud monitoring, customer operations, legal, dan people operations dengan koordinasi matriks untuk pengambilan keputusan harian.

Sebagian domain teknis telah menunjukkan kematangan tinggi, misalnya orkestrasi layanan mikro, enkripsi data transit, dan proses deployment otomatis berbasis persetujuan. Namun, pertumbuhan cepat juga menyisakan area yang belum seragam, seperti inventaris aset endpoint tim lapangan, standardisasi ruang kerja bersama, dan konsistensi offboarding untuk kontraktor jangka pendek.

Ground Truth (Terkoreksi):

Control ID: A.5.2

Control Title: Peran dan tanggung jawab keamanan informasi

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Menyoroti struktur peran, koordinasi lintas unit, dan akuntabilitas.

### Poin 3 - Ruang Lingkup dan Sasaran

Deskripsi:

Ruang lingkup SRS meliputi modul onboarding pelanggan, pemrosesan transaksi, manajemen akun internal, deteksi anomali, rekonsiliasi, pelaporan, serta integrasi dengan mitra perbankan. Sasaran utama

adalah menjaga integritas transaksi, keakuratan saldo, dan ketersediaan layanan pada jam operasional tinggi.

Dokumen ini juga memuat sasaran operasional terkait perilaku penggunaan perangkat kerja, media komunikasi digital, dan pengelolaan kredensial. Meskipun pedoman penggunaan yang dapat diterima telah dituangkan pada portal SDM, evaluasi periodik menunjukkan sebagian tim masih menggunakan kanal pesan pribadi untuk berbagi cuplikan log yang seharusnya tetap berada di repositori internal.

Ground Truth (Terkoreksi):

Control ID: A.5.10

Control Title: Penggunaan informasi dan aset terkait yang dapat diterima

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Ruang lingkup termasuk perilaku penggunaan email/internet yang dapat diterima.

#### **Poin 4 - Istilah dan Definisi**

Deskripsi:

Istilah transaksi kritis merujuk pada aktivitas pemindahan dana yang memengaruhi saldo pelanggan atau merchant. Istilah data sensitif mencakup data identitas pelanggan, token transaksi, detail rekening, serta artefak investigasi fraud yang memerlukan pembatasan akses ketat.

ArcPay menggunakan label klasifikasi informasi berupa publik, operasional internal, terbatas unit, dan rahasia perusahaan. Praktik pelabelan telah berjalan baik pada repositori dokumen pusat, namun artefak sementara di lingkungan pengujian masih ditemukan tanpa label yang konsisten sehingga meningkatkan kemungkinan paparan yang tidak disengaja.

Ground Truth (Terkoreksi):

Control ID: A.5.12

Control Title: Klasifikasi informasi

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Istilah dan definisi memuat skema klasifikasi informasi.

#### **Poin 5 - Tata Kelola dan Pengambilan Keputusan**

Deskripsi:

Keputusan arsitektur dan prioritas rilis ditetapkan melalui forum mingguan yang dihadiri engineering manager, product manager, risk representative, dan operations lead. Setiap perubahan besar wajib menyertakan analisis dampak terhadap layanan pelanggan, kapasitas infrastruktur, dan beban tim dukungan.

Pada kondisi insiden berdampak tinggi, keputusan perbaikan cepat kerap dilakukan langsung oleh tim on-call dengan koordinasi minimum agar layanan segera pulih. Walaupun efektif untuk menurunkan downtime, pendekatan ini sesekali meninggalkan ketidaksinkronan dokumentasi perubahan dan memperpanjang fase stabilisasi pascainsiden.

Ground Truth (Terkoreksi):

Control ID: A.5.2

Control Title: Peran dan tanggung jawab keamanan informasi

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Tata kelola keputusan terkait pembagian mandat dan tanggung jawab.

## **Poin 6 - Klasifikasi Informasi dan Pengelolaan Aset**

Deskripsi:

Seluruh komponen server, kontainer, dan kunci aplikasi tercatat dalam katalog aset teknis yang terintegrasi dengan pipeline deployment. Pendekatan ini mempermudah pemetaan ketergantungan layanan serta identifikasi komponen yang terdampak ketika ditemukan kerentanan.

Di sisi perangkat pengguna, pencatatan laptop dan ponsel kerja untuk tim tetap relatif tertib, sedangkan perangkat milik kontraktor dan mitra support belum selalu terdaftar pada siklus yang sama. Akibatnya, beberapa pembaruan kebijakan perangkat dan verifikasi konfigurasi tidak menjangkau seluruh pihak dengan hak akses ke sistem internal.

Ground Truth (Terkoreksi):

Control ID: A.5.9

Control Title: Inventarisasi informasi dan aset terkait lainnya

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Fokus pada inventarisasi/pengelolaan aset informasi.

## **Poin 7 - Penggunaan Email, Internet, dan Perangkat Kerja**

Deskripsi:

ArcPay mewajibkan penggunaan domain email perusahaan untuk komunikasi terkait pelanggan, mitra bank, dan regulator. Fitur deteksi lampiran berbahaya, perlindungan tautan, serta peringatan pengiriman keluar organisasi telah diaktifkan untuk mengurangi risiko kebocoran data.

Meskipun demikian, audit komunikasi internal mencatat praktik forwarding notifikasi layanan ke akun pribadi demi kemudahan akses mobile saat di luar jam kerja. Kebiasaan ini muncul karena sebagian tim belum memanfaatkan sepenuhnya aplikasi resmi mobile workplace yang telah disediakan perusahaan.

Ground Truth (Terkoreksi):

Control ID: A.5.10

Control Title: Penggunaan informasi dan aset terkait yang dapat diterima

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Membahas kebijakan penggunaan email, internet, dan perangkat kerja.

## **Poin 8 - SDM: Rekrutmen, Onboarding, dan Offboarding**

Deskripsi:

Untuk peran yang menangani alur pembayaran, perusahaan melakukan verifikasi identitas, referensi pekerjaan, dan evaluasi integritas profesional sebelum penawaran final. Onboarding mencakup sesi pemahaman risiko bisnis, simulasi skenario insiden, serta penandatanganan komitmen kerahasiaan data pelanggan.

Pada fase offboarding karyawan tetap, penarikan akses sistem berjalan terotomasi melalui sinkronisasi

HRIS dengan direktori identitas. Namun, untuk kontraktor berbasis proyek, pemutusan akses masih memerlukan konfirmasi manual dari vendor manager, sehingga terdapat jeda waktu pada beberapa kasus terminasi kontrak mendadak.

Ground Truth (Terkoreksi):

Control ID: A.6.5

Control Title: Tanggung jawab setelah pemutusan atau perubahan hubungan kerja

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Mencakup siklus onboarding-offboarding dan penarikan akses.

## **Poin 9 - Kesadaran dan Kompetensi Keamanan Informasi**

Deskripsi:

Program pelatihan ArcPay menekankan praktik aman dalam pengembangan perangkat lunak, pengelolaan token, dan komunikasi insiden antar tim. Tingkat kelulusan modul dasar relatif tinggi karena materi diintegrasikan ke target kinerja onboarding triwulan pertama.

Untuk topik lanjutan seperti analisis log forensik dan penanganan kampanye phishing bertarget, partisipasi belum merata antar squad. Beberapa tim produk menunda pelatihan karena tekanan roadmap fitur, sehingga kemampuan respons mendalam belum setara pada seluruh unit engineering.

Ground Truth (Terkoreksi):

Control ID: A.6.3

Control Title: Kesadaran, pendidikan, dan pelatihan keamanan informasi

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Membahas pelatihan dan kesadaran keamanan bagi personel.

## **Poin 10 - Pengamanan Fisik dan Lingkungan Kerja**

Deskripsi:

Kantor pusat ArcPay menggunakan akses kartu, area resepsionis terkendali, serta pemisahan area kerja tamu dan area operasional internal. Rak perangkat jaringan pada ruang infrastruktur lokal ditempatkan dalam kabinet terkunci dengan kontrol kunjungan vendor.

Praktik kerja hibrida menimbulkan tantangan baru, khususnya pada pengamanan layar dan percakapan sensitif di ruang publik. Meskipun pedoman clean desk dan clean screen telah diterbitkan, observasi internal menunjukkan penerapan belum konsisten di ruang kerja bersama dan lokasi kerja sementara.

Ground Truth (Terkoreksi):

Control ID: A.7.2

Control Title: Kontrol masuk fisik

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Pengendalian akses fisik dan perlindungan area kerja.

## **Poin 11 - Manajemen Identitas, Akses, dan Kriptografi**

#### Deskripsi:

Sistem produksi mensyaratkan autentikasi ganda untuk semua akun berprivilege, sementara hak akses aplikasi diatur berbasis peran yang ditinjau secara berkala oleh pemilik layanan. Kunci enkripsi dikelola terpusat dengan rotasi periodik dan pemisahan tugas antara pengelola platform dan pengembang fitur.

Pada aplikasi pendukung non-transaksional yang diadopsi sejak fase awal perusahaan, sebagian konfigurasi akses masih diwariskan dari pola lama berbasis grup umum. Dampaknya, penyesuaian hak akses saat perpindahan peran internal tidak selalu langsung tercermin pada seluruh alat kolaborasi.

#### Ground Truth (Terkoreksi):

Control ID: A.8.5

Control Title: Autentikasi yang aman

Applicable: Yes

Implementation Status: Implemented

Alasan Ringkas: Autentikasi aman/MFA dan kontrol akses berbasis peran.

### **Poin 12 - Operasi TI: Patch, Konfigurasi, dan Perubahan**

#### Deskripsi:

Patch keamanan untuk komponen kritis diprioritaskan melalui siklus cepat dengan validasi pada lingkungan staging dan canary release. Seluruh perubahan besar harus memuat rencana rollback, metrik keberhasilan, dan pemilik tindakan pascadeploy.

Dalam periode promosi produk dengan lonjakan transaksi, tim terkadang menunda patch non-kritis untuk menjaga stabilitas performa. Keputusan ini didokumentasikan sebagai risiko operasional, tetapi akumulasi penundaan dapat memperpanjang eksposur sistem terhadap kelemahan yang telah diketahui.

#### Ground Truth (Terkoreksi):

Control ID: A.8.8

Control Title: Manajemen kerentanan teknis

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Pengelolaan patch/kerentanan teknis dalam operasi perubahan.

### **Poin 13 - Pemantauan, Pencatatan, dan Respons Insiden**

#### Deskripsi:

ArcPay menggabungkan telemetry aplikasi, log keamanan, dan metrik infrastruktur pada pusat observabilitas untuk mendeteksi anomali transaksi maupun gangguan layanan. Tim fraud dan tim operasi menjalankan jalur koordinasi bersama agar kejadian teknis dan kejadian bisnis ditangani sebagai satu konteks.

Cakupan pemantauan pada layanan inti sudah memadai, namun beberapa integrasi pihak ketiga masih menghasilkan jejak log terbatas. Ketika anomali terjadi pada rantai integrasi tersebut, investigasi sering memerlukan permintaan data tambahan ke mitra yang memperlambat penentuan akar masalah.

#### Ground Truth (Terkoreksi):

Control ID: A.8.15

Control Title: Pencatatan log

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Pencatatan log, monitoring, dan keterlacakan insiden.

## **Poin 14 - Keandalan Layanan: Backup, Pemulihan, dan Keberlanjutan**

Deskripsi:

Data transaksi dan konfigurasi kritikal dicadangkan secara otomatis ke lokasi berbeda dengan verifikasi integritas berkala. Uji pemulihan dilakukan melalui simulasi gangguan terjadwal untuk memastikan prosedur operasional dapat dijalankan oleh tim lintas fungsi, bukan hanya oleh satu engineer senior.

Sementara itu, artefak analitik eksperimen produk tidak seluruhnya masuk ke skema backup yang sama karena dipandang bernilai sementara. Dalam beberapa kejadian, kehilangan data eksperimen memang tidak menghentikan layanan inti, tetapi menghambat evaluasi keputusan produk dan validasi model deteksi anomali.

Ground Truth (Terkoreksi):

Control ID: A.8.13

Control Title: Backup informasi

Applicable: Yes

Implementation Status: Implemented

Alasan Ringkas: Pencadangan, pemulihan, dan kesiapan layanan.

## **Poin 15 - Pengembangan Sistem dan Pengujian Keamanan**

Deskripsi:

ArcPay menerapkan secure coding guideline, pemeriksaan dependensi, dan tinjauan kode wajib pada jalur merge utama. Pengujian kerentanan otomatis dijalankan pada setiap pipeline rilis, disertai verifikasi manual untuk area dengan dampak finansial tinggi.

Kendala muncul pada proyek integrasi cepat dengan mitra baru, ketika tenggat bisnis mempersingkat waktu hardening dan dokumentasi arsitektur. Tim engineering tetap melakukan mitigasi minimum, namun beberapa temuan teknis ditunda ke backlog berikutnya sehingga memerlukan pengawasan ketat agar tidak menjadi utang operasional jangka panjang.

Ground Truth (Terkoreksi):

Control ID: A.8.28

Control Title: Pengkodean yang aman

Applicable: Yes

Implementation Status: Implemented

Alasan Ringkas: Praktik pengembangan aman dan uji keamanan aplikasi.

## **Poin 16 - Penutup**

Deskripsi:

SRS ini menjadi acuan tunggal bagi pengembangan dan operasi platform ArcPay agar pertumbuhan produk berjalan seimbang dengan disiplin pengelolaan risiko. Dokumen ini akan diperbarui mengikuti perubahan model layanan, teknologi, dan lanskap ancaman yang relevan dengan industri keuangan digital. ArcPay mengakui bahwa kematangan proses tidak berkembang secara serempak pada semua tim. Oleh karena itu, perbaikan berkelanjutan difokuskan pada area yang masih menunjukkan ketergantungan

manual, kesenjangan dokumentasi, dan variasi penerapan standar kerja aman di lingkungan kerja hibrida.

## Lampiran A. Matriks Peran

Matriks peran dalam dokumen ini menggunakan prinsip akuntabilitas berlapis. Unit pemilik proses bertanggung jawab atas pelaksanaan harian, sementara fungsi tata kelola melakukan pengawasan periodik berbasis risiko. Pada praktiknya, beberapa unit operasional masih mengandalkan personel kunci tertentu untuk keputusan teknis, sehingga kesinambungan keputusan berpotensi terganggu pada saat rotasi pegawai. Oleh karena itu, pembaruan matriks peran ditetapkan minimal dua kali setahun agar pendelegasian kewenangan terdokumentasi dengan lebih baik.

## Lampiran B. Alur Komunikasi

Alur komunikasi internal menempatkan jalur eskalasi formal untuk kejadian yang berdampak pada layanan inti, data personal, dan integritas sistem. Selain jalur formal, masih terdapat praktik komunikasi informal melalui grup percakapan lintas unit yang mempercepat koordinasi namun sering tidak meninggalkan jejak keputusan yang memadai. Untuk menjaga konsistensi dan keterlacakan, setiap keputusan operasional yang diambil secara cepat harus dirangkum kembali ke dalam kanal resmi dalam waktu kerja yang sama.

## Lampiran C. Ground Truth SoA Simulasi (Output LLM RAG)

Lampiran ini merupakan \_ground truth\_ simulasi yang dirumuskan dari pola output model pada direktori RAG\rag\iso\_rag\_project\results (terutama combined\_results.csv, analysis\_report.md, dan DataThesis.md), lalu diselaraskan dengan narasi dokumen ArcPay Teknologi Finansial pada fokus domain platform pembayaran, engineering, risiko operasional.

| No | Narasi Evidence Ringkas | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 1 | Forum arsitektur mingguan menetapkan prioritas keamanan layanan | A.5.1 | Yes | Implemented |

| 2 | Keputusan insiden darurat kadang mendahului dokumentasi formal | A.5.27 | Yes | Partially Implemented |

| 3 | Inventaris aset cloud lengkap, endpoint kontraktor belum menyeluruh | A.5.9 | Yes | Partially Implemented |

| 4 | Kebijakan email perusahaan kuat, forwarding ke akun pribadi masih ada | A.5.10 | Yes | Partially Implemented |

| 5 | Offboarding karyawan tetap otomatis, kontraktor masih manual | A.5.11 | Yes | Partially Implemented |

| 6 | Klasifikasi data diterapkan pada repositori pusat | A.5.12 | Yes | Implemented |

| 7 | Verifikasi personel pada fungsi pembayaran diterapkan sebelum akses | A.6.1 | Yes | Implemented |

| 8 | Pelatihan dasar wajib, pelatihan lanjutan belum merata per squad | A.6.3 | Yes | Partially Implemented |

| 9 | Kebersihan ruang kerja hibrida belum konsisten | A.7.7 | Yes | Partially Implemented |

| 10 | Area kantor dipisah antara tamu dan internal | A.7.2 | Yes | Implemented |

| 11 | RBAC dan MFA untuk privilege account telah aktif | A.8.2 | Yes | Implemented |

| 12 | Rotasi kunci enkripsi terpusat berjalan periodik | A.8.24 | Yes | Implemented |

| 13 | Patch kritis diprioritaskan, non-kritis kadang ditunda | A.8.8 | Yes | Partially Implemented |

| 14 | Observabilitas terpusat ada, integrasi pihak ketiga terbatas | A.8.15 | Yes | Partially Implemented |

| 15 | Backup data transaksi diuji dengan simulasi gangguan | A.8.13 | Yes | Implemented |

| 16 | Secure coding pipeline diterapkan pada jalur merge utama | A.8.28 | Yes | Implemented |

| 17 | Pemisahan staging, canary, dan produksi telah dijalankan | A.8.31 | Yes | Implemented |

| 18 | Integrasi cepat mitra kadang menunda hardening penuh | A.8.25 | Yes | Partially Implemented |

Ringkasan ini sengaja memuat sinyal positif dan negatif secara bersamaan agar dataset tetap realistis

untuk kebutuhan analisis SoA otomatis. Beberapa butir bernilai *\*Partially Implemented\** untuk merepresentasikan kondisi organisasi yang telah memiliki kebijakan namun belum konsisten pada implementasi unit kerja tertentu.

#### **Lampiran D. Narasi Tambahan untuk Pengayaan Dokumen**

Dalam evaluasi semesteran, organisasi menegaskan bahwa perbaikan tata kelola tidak cukup diukur dari keberadaan kebijakan tertulis, melainkan dari konsistensi penerapan lintas unit dan keterlacakan keputusan operasional. Pola ini penting karena banyak risiko muncul pada titik transisi proses, seperti perpindahan personel, perpindahan aset, dan perubahan konfigurasi layanan pada periode beban puncak. Unit pengawasan internal mencatat bahwa praktik yang terlihat baik pada level pusat belum tentu tercermin di unit satelit, cabang, atau area operasional khusus. Oleh sebab itu, pendekatan evaluasi diarahkan pada pembuktian lapangan, termasuk verifikasi jejak audit, kecukupan dokumentasi persetujuan, dan ketepatan waktu tindak lanjut setelah temuan inspeksi.

Kapasitas SDM menjadi faktor pembeda utama antara unit yang mampu menjaga disiplin operasional dan unit yang masih bergantung pada inisiatif individu. Investasi pada pelatihan teknis, pelatihan perilaku kerja aman, serta simulasi insiden berkala terbukti mempercepat respons dan menurunkan insiden berulang yang disebabkan oleh kesalahan prosedural.

Pada aspek teknologi, organisasi menilai bahwa penguatan autentikasi, pemisahan hak akses, dan pemantauan log harus berjalan beriringan. Penerapan salah satu komponen tanpa komponen lain sering menghasilkan ilusi kendali: akses mungkin terlihat ketat, namun anomali tidak terdeteksi atau tidak dapat ditelusuri secara memadai ketika kejadian berlangsung lintas sistem.

Untuk menjamin kesinambungan layanan, kebutuhan pemulihan tidak hanya ditentukan oleh ketersediaan salinan cadangan, tetapi juga oleh kesiapan personel menjalankan prosedur di bawah tekanan waktu. Simulasi pemulihan yang melibatkan fungsi bisnis dan fungsi teknis sekaligus dinilai lebih representatif dibanding pengujian terbatas oleh tim infrastruktur saja.

Organisasi juga menekankan bahwa perubahan cepat tetap dapat dijalankan secara tertib apabila setiap perubahan memiliki pemilik yang jelas, catatan keputusan yang ringkas, dan verifikasi pascaperubahan. Praktik tersebut mengurangi risiko regresi tersembunyi, terutama ketika perubahan dilakukan pada jam non-standar untuk menjaga ketersediaan layanan.

Selain aspek teknis, keberhasilan penguatan tata kelola sangat dipengaruhi budaya eskalasi yang sehat. Unit kerja didorong untuk melaporkan kerentanan proses dan deviasi praktik tanpa menunggu terjadinya insiden besar, sehingga tindakan korektif dapat dilakukan lebih awal dan biaya pemulihan tetap terkendali.

#### **Lampiran E. Ground Truth Per Poin (Point-by-Point)**

Lampiran ini menyajikan ground truth untuk setiap poin inti (1-16) pada dokumen.

##### **Poin 1 - Pendahuluan**

Deskripsi:

Dokumen spesifikasi ini mendefinisikan kebutuhan fungsional dan nonfungsional untuk platform pembayaran digital ArcPay yang melayani transfer dana, disbursement merchant, verifikasi identitas, dan pelaporan transaksi. Sifat layanan yang selalu aktif menuntut desain sistem yang andal, aman, dan mampu dipulihkan dengan cepat ketika terjadi gangguan.

ArcPay berkembang dari tim kecil dengan siklus rilis sangat cepat. Pola tersebut menghasilkan inovasi produk yang kompetitif, namun juga meninggalkan variasi dokumentasi antarfitur. Dokumen ini mengonsolidasikan kebutuhan lintas divisi agar proses pengembangan, operasi, dan pengawasan memiliki rujukan tunggal yang dapat diaudit secara internal.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 1 | Kebutuhan sistem keamanan dan keandalan platform terdokumentasi jelas | A.5.8 | Yes | Implemented |

## Poin 2 - Latar Belakang Organisasi

Deskripsi:

Sebagai perusahaan teknologi finansial tahap pertumbuhan, ArcPay mengoperasikan layanan pada infrastruktur cloud publik dan pusat data mitra pembayaran. Struktur organisasi menggabungkan engineering, fraud monitoring, customer operations, legal, dan people operations dengan koordinasi matriks untuk pengambilan keputusan harian.

Sebagian domain teknis telah menunjukkan kematangan tinggi, misalnya orkestrasi layanan mikro, enkripsi data transit, dan proses deployment otomatis berbasis persetujuan. Namun, pertumbuhan cepat juga menyisakan area yang belum seragam, seperti inventaris aset endpoint tim lapangan, standardisasi ruang kerja bersama, dan konsistensi offboarding untuk kontraktor jangka pendek.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 2 | Fondasi teknis matang, pengelolaan endpoint dan offboarding kontraktor belum seragam | A.5.9 | Yes | Partially Implemented |

## Poin 3 - Ruang Lingkup dan Sasaran

Deskripsi:

Ruang lingkup SRS meliputi modul onboarding pelanggan, pemrosesan transaksi, manajemen akun internal, deteksi anomali, rekonsiliasi, pelaporan, serta integrasi dengan mitra perbankan. Sasaran utama adalah menjaga integritas transaksi, keakuratan saldo, dan ketersediaan layanan pada jam operasional tinggi.

Dokumen ini juga memuat sasaran operasional terkait perilaku penggunaan perangkat kerja, media komunikasi digital, dan pengelolaan kredensial. Meskipun pedoman penggunaan yang dapat diterima telah dituangkan pada portal SDM, evaluasi periodik menunjukkan sebagian tim masih menggunakan kanal pesan pribadi untuk berbagi cuplikan log yang seharusnya tetap berada di repositori internal.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 3 | Sasaran operasional kuat, penggunaan kanal pribadi untuk log masih terjadi | A.5.10 | Yes | Partially Implemented |

## Poin 4 - Istilah dan Definisi

Deskripsi:

Istilah transaksi kritical merujuk pada aktivitas pemindahan dana yang memengaruhi saldo pelanggan atau merchant. Istilah data sensitif mencakup data identitas pelanggan, token transaksi, detail rekening, serta artefak investigasi fraud yang memerlukan pembatasan akses ketat.

ArcPay menggunakan label klasifikasi informasi berupa publik, operasional internal, terbatas unit, dan rahasia perusahaan. Praktik pelabelan telah berjalan baik pada repositori dokumen pusat, namun artefak sementara di lingkungan pengujian masih ditemukan tanpa label yang konsisten sehingga meningkatkan kemungkinan paparan yang tidak disengaja.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 4 | Klasifikasi data tersedia, artefak lingkungan uji belum konsisten diberi label | A.5.12 | Yes | Partially Implemented |

## **Poin 5 - Tata Kelola dan Pengambilan Keputusan**

Deskripsi:

Keputusan arsitektur dan prioritas rilis ditetapkan melalui forum mingguan yang dihadiri engineering manager, product manager, risk representative, dan operations lead. Setiap perubahan besar wajib menyertakan analisis dampak terhadap layanan pelanggan, kapasitas infrastruktur, dan beban tim dukungan.

Pada kondisi insiden berdampak tinggi, keputusan perbaikan cepat kerap dilakukan langsung oleh tim on-call dengan koordinasi minimum agar layanan segera pulih. Walaupun efektif untuk menurunkan downtime, pendekatan ini sesekali meninggalkan ketidaksinkronan dokumentasi perubahan dan memperpanjang fase stabilisasi pascainsiden.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 5 | Governance arsitektur rutin, respons darurat kadang mendahului catatan formal | A.5.37 | Yes | Partially Implemented |

## **Poin 6 - Klasifikasi Informasi dan Pengelolaan Aset**

Deskripsi:

Seluruh komponen server, kontainer, dan kunci aplikasi tercatat dalam katalog aset teknis yang terintegrasi dengan pipeline deployment. Pendekatan ini mempermudah pemetaan ketergantungan layanan serta identifikasi komponen yang terdampak ketika ditemukan kerentanan.

Di sisi perangkat pengguna, pencatatan laptop dan ponsel kerja untuk tim tetap relatif tertib, sedangkan perangkat milik kontraktor dan mitra support belum selalu terdaftar pada siklus yang sama. Akibatnya, beberapa pembaruan kebijakan perangkat dan verifikasi konfigurasi tidak menjangkau seluruh pihak dengan hak akses ke sistem internal.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 6 | Katalog aset cloud baik, perangkat kontraktor belum sepenuhnya tercatat | A.5.9 | Yes | Partially Implemented |

## **Poin 7 - Penggunaan Email, Internet, dan Perangkat Kerja**

Deskripsi:

ArcPay mewajibkan penggunaan domain email perusahaan untuk komunikasi terkait pelanggan, mitra bank, dan regulator. Fitur deteksi lampiran berbahaya, perlindungan tautan, serta peringatan pengiriman keluar organisasi telah diaktifkan untuk mengurangi risiko kebocoran data.

Meskipun demikian, audit komunikasi internal mencatat praktik forwarding notifikasi layanan ke akun pribadi demi kemudahan akses mobile saat di luar jam kerja. Kebiasaan ini muncul karena sebagian tim belum memanfaatkan sepenuhnya aplikasi resmi mobile workplace yang telah disediakan perusahaan.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 7 | Perlindungan email diterapkan, forwarding ke akun pribadi masih ditemukan | A.5.10 | Yes | Partially Implemented |

## **Poin 8 - SDM: Rekrutmen, Onboarding, dan Offboarding**

Deskripsi:

Untuk peran yang menangani alur pembayaran, perusahaan melakukan verifikasi identitas, referensi pekerjaan, dan evaluasi integritas profesional sebelum penawaran final. Onboarding mencakup sesi pemahaman risiko bisnis, simulasi skenario insiden, serta penandatanganan komitmen kerahasiaan data pelanggan.

Pada fase offboarding karyawan tetap, penarikan akses sistem berjalan terotomasi melalui sinkronisasi HRIS dengan direktori identitas. Namun, untuk kontraktor berbasis proyek, pemutusan akses masih memerlukan konfirmasi manual dari vendor manager, sehingga terdapat jeda waktu pada beberapa kasus terminasi kontrak mendadak.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 8 | Verifikasi rekrutmen baik, penutupan akses kontraktor masih manual | A.6.5 | Yes | Partially Implemented |

## **Poin 9 - Kesadaran dan Kompetensi Keamanan Informasi**

Deskripsi:

Program pelatihan ArcPay menekankan praktik aman dalam pengembangan perangkat lunak, pengelolaan token, dan komunikasi insiden antar tim. Tingkat kelulusan modul dasar relatif tinggi karena materi diintegrasikan ke target kinerja onboarding triwulan pertama.

Untuk topik lanjutan seperti analisis log forensik dan penanganan kampanye phishing bertarget, partisipasi belum merata antar squad. Beberapa tim produk menunda pelatihan karena tekanan roadmap fitur, sehingga kemampuan respons mendalam belum setara pada seluruh unit engineering.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 9 | Pelatihan dasar wajib, pelatihan lanjutan belum merata di semua squad | A.6.3 | Yes | Partially Implemented |

## **Poin 10 - Pengamanan Fisik dan Lingkungan Kerja**

Deskripsi:

Kantor pusat ArcPay menggunakan akses kartu, area resepsionis terkendali, serta pemisahan area kerja tamu dan area operasional internal. Rak perangkat jaringan pada ruang infrastruktur lokal ditempatkan dalam kabinet terkunci dengan kontrol kunjungan vendor.

Praktik kerja hibrida menimbulkan tantangan baru, khususnya pada pengamanan layar dan percakapan sensitif di ruang publik. Meskipun pedoman clean desk dan clean screen telah diterbitkan, observasi internal menunjukkan penerapan belum konsisten di ruang kerja bersama dan lokasi kerja sementara.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 10 | Akses fisik kantor terkendali, kebiasaan clean screen di kerja hibrida belum konsisten | A.7.7 | Yes | Partially Implemented |

## **Poin 11 - Manajemen Identitas, Akses, dan Kriptografi**

Deskripsi:

Sistem produksi mensyaratkan autentikasi ganda untuk semua akun berprivilege, sementara hak akses aplikasi diatur berbasis peran yang ditinjau secara berkala oleh pemilik layanan. Kunci enkripsi dikelola terpusat dengan rotasi periodik dan pemisahan tugas antara pengelola platform dan pengembang fitur.

Pada aplikasi pendukung non-transaksional yang diadopsi sejak fase awal perusahaan, sebagian konfigurasi akses masih diwariskan dari pola lama berbasis grup umum. Dampaknya, penyesuaian hak akses saat perpindahan peran internal tidak selalu langsung tercermin pada seluruh alat kolaborasi.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 11 | MFA, RBAC, dan pengelolaan kunci enkripsi terpusat telah berjalan | A.8.24 | Yes | Implemented |

## **Poin 12 - Operasi TI: Patch, Konfigurasi, dan Perubahan**

Deskripsi:

Patch keamanan untuk komponen kritis diprioritaskan melalui siklus cepat dengan validasi pada lingkungan staging dan canary release. Seluruh perubahan besar harus memuat rencana rollback, metrik keberhasilan, dan pemilik tindakan pascadeploy.

Dalam periode promosi produk dengan lonjakan transaksi, tim terkadang menunda patch non-kritis untuk menjaga stabilitas performa. Keputusan ini didokumentasikan sebagai risiko operasional, tetapi akumulasi penundaan dapat memperpanjang eksposur sistem terhadap kelemahan yang telah diketahui.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 12 | Patch kritis cepat, patch non-kritis kadang ditunda saat beban tinggi | A.8.8 | Yes | Partially Implemented |

## **Poin 13 - Pemantauan, Pencatatan, dan Respons Insiden**

Deskripsi:

ArcPay menggabungkan telemetry aplikasi, log keamanan, dan metrik infrastruktur pada pusat observabilitas untuk mendeteksi anomali transaksi maupun gangguan layanan. Tim fraud dan tim operasi menjalankan jalur koordinasi bersama agar kejadian teknis dan kejadian bisnis ditangani sebagai satu konteks.

Cakupan pemantauan pada layanan inti sudah memadai, namun beberapa integrasi pihak ketiga masih menghasilkan jejak log terbatas. Ketika anomali terjadi pada rantai integrasi tersebut, investigasi sering memerlukan permintaan data tambahan ke mitra yang memperlambat penentuan akar masalah.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 13 | Observabilitas terintegrasi tersedia, log pihak ketiga belum memadai | A.8.15 | Yes | Partially Implemented |

## **Poin 14 - Keandalan Layanan: Backup, Pemulihan, dan Keberlanjutan**

Deskripsi:

Data transaksi dan konfigurasi kritis dicadangkan secara otomatis ke lokasi berbeda dengan verifikasi integritas berkala. Uji pemulihan dilakukan melalui simulasi gangguan terjadwal untuk memastikan prosedur operasional dapat dijalankan oleh tim lintas fungsi, bukan hanya oleh satu engineer senior.

Sementara itu, artefak analitik eksperimen produk tidak seluruhnya masuk ke skema backup yang sama

karena dipandang bernilai sementara. Dalam beberapa kejadian, kehilangan data eksperimen memang tidak menghentikan layanan inti, tetapi menghambat evaluasi keputusan produk dan validasi model deteksi anomali.

Ground Truth:

|  | Poin | Ringkasan Evidence                                    | Prediksi Annex Control | Applicability | Implementation Status |
|--|------|-------------------------------------------------------|------------------------|---------------|-----------------------|
|  | ---  | ---                                                   | ---                    | ---           | ---                   |
|  | 14   | Backup data transaksi dan uji pemulihan berjalan baik | A.8.13                 | Yes           | Implemented           |

## Poin 15 - Pengembangan Sistem dan Pengujian Keamanan

Deskripsi:

ArcPay menerapkan secure coding guideline, pemeriksaan dependensi, dan tinjauan kode wajib pada jalur merge utama. Pengujian kerentanan otomatis dijalankan pada setiap pipeline rilis, disertai verifikasi manual untuk area dengan dampak finansial tinggi.

Kendala muncul pada proyek integrasi cepat dengan mitra baru, ketika tenggat bisnis mempersingkat waktu hardening dan dokumentasi arsitektur. Tim engineering tetap melakukan mitigasi minimum, namun beberapa temuan teknis ditunda ke backlog berikutnya sehingga memerlukan pengawasan ketat agar tidak menjadi utang operasional jangka panjang.

Ground Truth:

|  | Poin | Ringkasan Evidence                                                   | Prediksi Annex Control | Applicability | Implementation Status |
|--|------|----------------------------------------------------------------------|------------------------|---------------|-----------------------|
|  | ---  | ---                                                                  | ---                    | ---           | ---                   |
|  | 15   | Secure coding dan pengujian kerentanan sudah menjadi praktik standar | A.8.28                 | Yes           | Implemented           |

## Poin 16 - Penutup

Deskripsi:

SRS ini menjadi acuan tunggal bagi pengembangan dan operasi platform ArcPay agar pertumbuhan produk berjalan seimbang dengan disiplin pengelolaan risiko. Dokumen ini akan diperbarui mengikuti perubahan model layanan, teknologi, dan lanskap ancaman yang relevan dengan industri keuangan digital. ArcPay mengakui bahwa kematangan proses tidak berkembang secara serempak pada semua tim. Oleh karena itu, perbaikan berkelanjutan difokuskan pada area yang masih menunjukkan ketergantungan manual, kesenjangan dokumentasi, dan variasi penerapan standar kerja aman di lingkungan kerja hibrida.

## Lampiran A. Matriks Peran

Matriks peran dalam dokumen ini menggunakan prinsip akuntabilitas berlapis. Unit pemilik proses bertanggung jawab atas pelaksanaan harian, sementara fungsi tata kelola melakukan pengawasan periodik berbasis risiko. Pada praktiknya, beberapa unit operasional masih mengandalkan personel kunci tertentu untuk keputusan teknis, sehingga kesinambungan keputusan berpotensi terganggu pada saat rotasi pegawai. Oleh karena itu, pembaruan matriks peran ditetapkan minimal dua kali setahun agar pendelegasian kewenangan terdokumentasi dengan lebih baik.

## Lampiran B. Alur Komunikasi

Alur komunikasi internal menempatkan jalur eskalasi formal untuk kejadian yang berdampak pada layanan inti, data personal, dan integritas sistem. Selain jalur formal, masih terdapat praktik komunikasi informal melalui grup percakapan lintas unit yang mempercepat koordinasi namun sering tidak meninggalkan jejak keputusan yang memadai. Untuk menjaga konsistensi dan keterlacakan, setiap keputusan operasional yang diambil secara cepat harus dirangkum kembali ke dalam kanal resmi dalam waktu kerja yang sama.

## Lampiran C. Ground Truth SoA Simulasi (Output LLM RAG)

Lampiran ini merupakan \_ground truth\_ simulasi yang dirumuskan dari pola output model pada direktori

RAG\rag\iso\_rag\_project\results (terutama combined\_results.csv, analysis\_report.md, dan DataThesis.md), lalu diselaraskan dengan narasi dokumen ArcPay Teknologi Finansial pada fokus domain platform pembayaran, engineering, risiko operasional.

| No | Narasi Evidence Ringkas | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 1 | Forum arsitektur mingguan menetapkan prioritas keamanan layanan | A.5.1 | Yes | Implemented |

| 2 | Keputusan insiden darurat kadang mendahului dokumentasi formal | A.5.27 | Yes | Partially Implemented |

| 3 | Inventaris aset cloud lengkap, endpoint kontraktor belum menyeluruh | A.5.9 | Yes | Partially Implemented |

| 4 | Kebijakan email perusahaan kuat, forwarding ke akun pribadi masih ada | A.5.10 | Yes | Partially Implemented |

| 5 | Offboarding karyawan tetap otomatis, kontraktor masih manual | A.5.11 | Yes | Partially Implemented |

| 6 | Klasifikasi data diterapkan pada repositori pusat | A.5.12 | Yes | Implemented |

| 7 | Verifikasi personel pada fungsi pembayaran diterapkan sebelum akses | A.6.1 | Yes | Implemented |

| 8 | Pelatihan dasar wajib, pelatihan lanjutan belum merata per squad | A.6.3 | Yes | Partially Implemented |

| 9 | Kebersihan ruang kerja hibrida belum konsisten | A.7.7 | Yes | Partially Implemented |

| 10 | Area kantor dipisah antara tamu dan internal | A.7.2 | Yes | Implemented |

| 11 | RBAC dan MFA untuk privilege account telah aktif | A.8.2 | Yes | Implemented |

| 12 | Rotasi kunci enkripsi terpusat berjalan periodik | A.8.24 | Yes | Implemented |

| 13 | Patch kritikal diprioritaskan, non-kritikal kadang ditunda | A.8.8 | Yes | Partially Implemented |

| 14 | Observabilitas terpusat ada, integrasi pihak ketiga terbatas | A.8.15 | Yes | Partially Implemented |

| 15 | Backup data transaksi diuji dengan simulasi gangguan | A.8.13 | Yes | Implemented |

| 16 | Secure coding pipeline diterapkan pada jalur merge utama | A.8.28 | Yes | Implemented |

| 17 | Pemisahan staging, canary, dan produksi telah dijalankan | A.8.31 | Yes | Implemented |

| 18 | Integrasi cepat mitra kadang menunda hardening penuh | A.8.25 | Yes | Partially Implemented |

Ringkasan ini sengaja memuat sinyal positif dan negatif secara bersamaan agar dataset tetap realistis untuk kebutuhan analisis SoA otomatis. Beberapa butir bernilai \*Partially Implemented\* untuk merepresentasikan kondisi organisasi yang telah memiliki kebijakan namun belum konsisten pada implementasi unit kerja tertentu.

## Lampiran D. Narasi Tambahan untuk Pengayaan Dokumen

Dalam evaluasi semesteran, organisasi menegaskan bahwa perbaikan tata kelola tidak cukup diukur dari keberadaan kebijakan tertulis, melainkan dari konsistensi penerapan lintas unit dan keterlacakan keputusan operasional. Pola ini penting karena banyak risiko muncul pada titik transisi proses, seperti perpindahan personel, perpindahan aset, dan perubahan konfigurasi layanan pada periode beban puncak. Unit pengawasan internal mencatat bahwa praktik yang terlihat baik pada level pusat belum tentu tercermin di unit satelit, cabang, atau area operasional khusus. Oleh sebab itu, pendekatan evaluasi diarahkan pada pembuktian lapangan, termasuk verifikasi jejak audit, kecukupan dokumentasi persetujuan, dan ketepatan waktu tindak lanjut setelah temuan inspeksi.

Kapasitas SDM menjadi faktor pembeda utama antara unit yang mampu menjaga disiplin operasional dan unit yang masih bergantung pada inisiatif individu. Investasi pada pelatihan teknis, pelatihan perilaku kerja aman, serta simulasi insiden berkala terbukti mempercepat respons dan menurunkan insiden berulang yang disebabkan oleh kesalahan prosedural.

Pada aspek teknologi, organisasi menilai bahwa penguatan autentikasi, pemisahan hak akses, dan

pemantauan log harus berjalan beriringan. Penerapan salah satu komponen tanpa komponen lain sering menghasilkan ilusi kendali: akses mungkin terlihat ketat, namun anomali tidak terdeteksi atau tidak dapat ditelusuri secara memadai ketika kejadian berlangsung lintas sistem.

Untuk menjamin kesinambungan layanan, kebutuhan pemulihan tidak hanya ditentukan oleh ketersediaan salinan cadangan, tetapi juga oleh kesiapan personel menjalankan prosedur di bawah tekanan waktu. Simulasi pemulihan yang melibatkan fungsi bisnis dan fungsi teknis sekaligus dinilai lebih representatif dibanding pengujian terbatas oleh tim infrastruktur saja.

Organisasi juga menekankan bahwa perubahan cepat tetap dapat dijalankan secara tertib apabila setiap perubahan memiliki pemilik yang jelas, catatan keputusan yang ringkas, dan verifikasi pascaperubahan. Praktik tersebut mengurangi risiko regresi tersembunyi, terutama ketika perubahan dilakukan pada jam non-standar untuk menjaga ketersediaan layanan.

Selain aspek teknis, keberhasilan penguatan tata kelola sangat dipengaruhi budaya eskalasi yang sehat. Unit kerja didorong untuk melaporkan kerentanan proses dan deviasi praktik tanpa menunggu terjadinya insiden besar, sehingga tindakan korektif dapat dilakukan lebih awal dan biaya pemulihan tetap terkendali.

Ground Truth:

| Poin | Ringkasan Evidence | Prediksi Annex Control | Applicability | Implementation Status |

| --- | --- | --- | --- | --- |

| 16 | Perbaikan berkelanjutan difokuskan pada area yang masih bergantung proses manual | A.5.36 | Yes

| Partially Implemented |

Ground Truth (Terkoreksi):

Control ID: A.5.4

Control Title: Tanggung jawab manajemen

Applicable: Yes

Implementation Status: Partially Implemented

Alasan Ringkas: Penegasan komitmen manajemen terhadap perbaikan berkelanjutan.